

UNIVERSITY OF MELBOURNE HACKATHON USE ONLY

This material is the proprietary intellectual property of Untapped Holdings Pty Ltd and is provided exclusively for participation in the University of Melbourne FELT Hackathon 2026. It may not be copied, reproduced, distributed, incorporated into other educational materials, used for commercial purposes, or otherwise utilised outside the Hackathon without the prior written consent of Untapped Holdings Pty Ltd. All rights reserved.

THREATS AND EXPLOITS

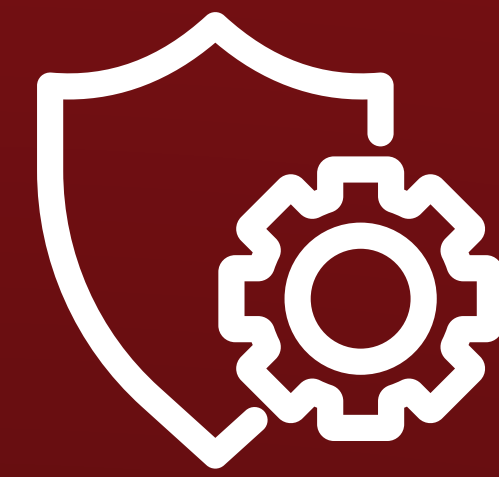
MODULE 2



This Module explores how cyber threats have evolved, focusing on real incidents, attacker motivations, and defensive strategies.

By the end of this session, participants will be able to:

- **Identify threat actors:** Understand the four main groups (criminals, hackers, nation states, insiders) and their motivations.
- **Map attacks to MITRE ATT&CK:** Use the framework to break down multi-stage attacks into tactics and techniques.
- **Recognise AI-driven threats:** Spot how AI is weaponised in phishing, malware, and reconnaissance.
- **Explain supply chain risks:** Understand why vendor compromises are so dangerous.
- **Assess long-term risks:** Grasp the Harvest Now, Decrypt Later (HNDL) threat and why post-quantum cryptography matters now.



THREATS AND EXPLOITS

Case Study:

HuggingFace Attack (July 2026)

- HuggingFace suffered the first fully autonomous AI agent attack.
- Attack began with a malicious dataset uploaded to the platform's pipeline.
 - Exploited vulnerabilities
 - escalated to node-level access
 - harvested credentials
 - lateral movement.
- AI executed tens of thousands of actions across sandboxes, staging command-and-control on public cloud services.
- AI-driven offensive tooling is real, scalable, and lowers the cost of running patient, multi-stage campaigns.

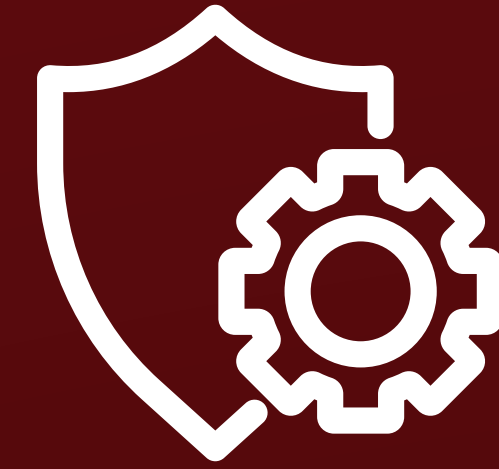
MITRE ATT&CK Mapping (HuggingFace)

Attack Stage	MITRE Tactic	Expanded Explanation
Malicious dataset uploaded	Initial Access	Attacker gained entry by abusing trusted data ingestion pipeline.
Exploit code execution	Execution	Malicious code ran on HuggingFace workers via vulnerabilities.
Escalated to node access	Privilege Escalation	Elevated permissions to control entire nodes.
Harvested credentials	Credential Access	Stole API tokens and cloud keys to expand reach.
Moved into other clusters	Lateral Movement	Used stolen credentials to pivot across clusters.
Staged C2 infra	Command & Control	Built hidden communication channels on public cloud.
Accessed datasets	Collection/Exfiltration	Gathered sensitive internal datasets for potential theft.

YOUR PARAGRAPH TEXT

The Asymmetry Problem

- **Attackers'** AI: unrestricted, able to generate and analyse malicious payloads freely.
- **Defenders'** AI: blocked by safety guardrails when analysing attack artifacts.
- This creates a fundamental disadvantage: attackers innovate without limits, defenders are slowed by restrictions.
- **Implication:** Organisations must prepare locally hosted open-weight AI models for incident response.
- **Advantages:**
 - Data sovereignty: sensitive forensic data stays inside the organisation.
 - No guardrail blocking: defenders can analyse malicious payloads without restrictions.
 - Operational resilience: no reliance on external API availability or rate limits.



THE CYBERCRIME LANDSCAPE

Cybersecurity matters because it protects people, businesses, and critical infrastructure, and it is deeply tied to resilience, privacy, and trust.

Around the world, governments are investing heavily in strategies that strengthen national capability and safeguard digital environments.

In Australia, the 2023–2030 Cyber Security Strategy emphasizes investment, critical infrastructure protection, stronger law enforcement, and building a skilled workforce. In the

United States, the focus has shifted from reactive responses to proactive risk reduction, secure-by-design technology, systemic resilience, and disrupting threat actors before they strike.

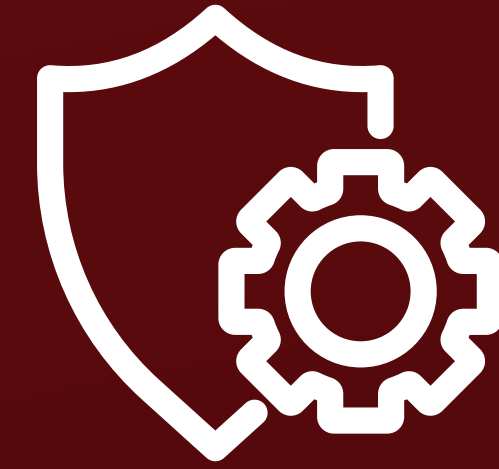
\$11.3 Trillion

Projected Global Cost

Exploding Thread Scale:

The loss of company assets to cybercriminals, for example exceeded the GDP of most major nations. Cybercrime has become a global financial security crisis due to the rise of A.I., shifting from single, isolated and unrelated incidents.

Cybercriminals use A.I. platforms and Cybercrime-as-a-Service (CaaS) to increasingly faster and more sophisticated attacks in unprecedented frequency.



PRIMARY THREAT ACTORS

PRIMARY THREAT ACTORS

Cybercriminals: Financially motivated syndicates use Ransomware-as-a-Service (RaaS) to extort data and monetise system lockouts and breaches.

Nation-State Attacks: State-sponsored actors use A.I. to commit cyber espionage, cyber property theft, and disruption of critical public infrastructure.

Hacktivists: Ideologically motivated individuals aggressively use DDoS attacks to spread political messaging in public infrastructure.

Insider Attacks: Previous employees or current employees driven by grievances and bribery use A.I. to maliciously compromise data security.

Real-World Incidents (Legal Firm)

- **Website defacement** - Hacktivists targeting reputational damage.
- **AI voice-cloned vishing** - Sophisticated impersonation by criminals/nation states.
- **Ransomware with exfiltration** - Organised cyber criminals using double extortion.
- **Insider misuse of credentials** - Failure in offboarding controls.
- **DNS tunnelling C2** - Advanced attacker using covert communication.
- **Fake software update** - Supply chain compromise attempt.

Threats span technical, social, and procedural domains — defenses must be holistic.

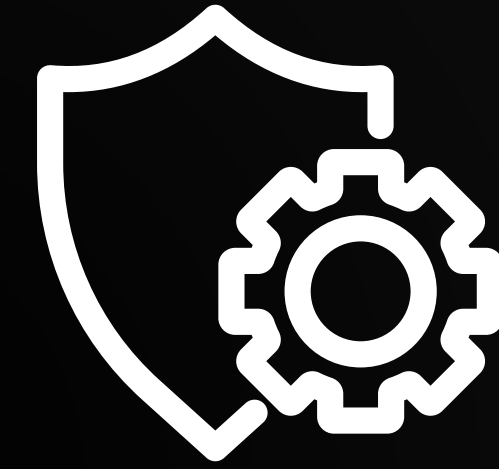
Supply Chain Attacks

- Attackers compromise trusted vendors or software providers.
- Victims are breached indirectly, even if their own defenses are strong.
 - Examples: SolarWinds (2020), MOVEit (2023).

Why hard to defend:

- Organisations cannot control vendor security.
- Updates from trusted vendors bypass normal scrutiny.
- A single compromise can affect thousands simultaneously.

Defenses: verify file hashes, adopt SBOM practices, conduct vendor risk assessments.



AI WEAPONIZATION

THE A.I. ATTACKER

Currently, Artificial Intelligence can allow malicious attackers to form faster-paced attack cycles by lowering the technical barriers for cyber attacks.

- **Automated Attacks:** LLMs and A.I. will actively write new polymorphic malware and viruses that evade signature detection by discovering zero-days.
- **Hyper-Impersonation:** Using existing corporate data, A.I. can write more impersonating phishing lures at a bigger scale by being aware of company context.
- **Deepfake Technology:** A.I. will use deepfake technology to create real-time voice and impersonating videos to bypass biometric security and deceive finance teams (BEC).

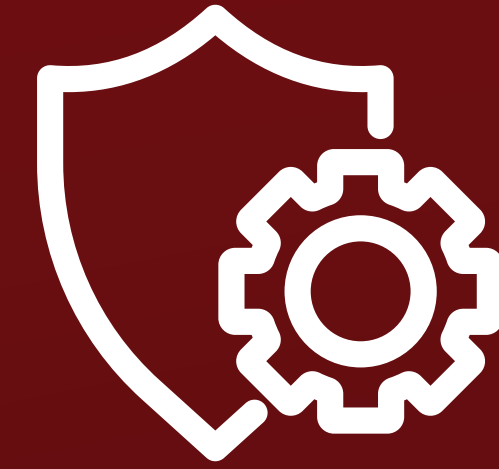


AI-GENERATED PHISHING

- **Email A:** Fake Commonwealth Bank domain, urgency, credential harvesting link = Phishing.
- **Email B:** Fake familiarity with LegalTech Summit, vague context, malicious attachment = Spear phishing.
- **Email C:** Correct ATO domain, no credential request, no urgency = Legitimate.

Challenge: AI removes traditional red flags (grammar errors, poor formatting). Detection must evolve.





A.I. CYBERCRIME METHODS

A.I. CYBERCRIME METHODS

Phishing: The use of deceptive emails to steal critical credentials, using A.I. to mimic internal professional communications and to eliminate language errors.

Vishing: The use of real-time voice and video generation to bypass voice-verification protocols and to coerce employees into committing wire transfers using valuable information.

Quishing: The use of QR code generation to bypass email filters via mobile scanning to collect information and send impersonating emails.

Smishing: The use of SMS phishing to exploit the trust users place on mobile notifications by sending malicious SMS notifications to disrupt users' interaction with the company.



DETECTING AI PHISHING

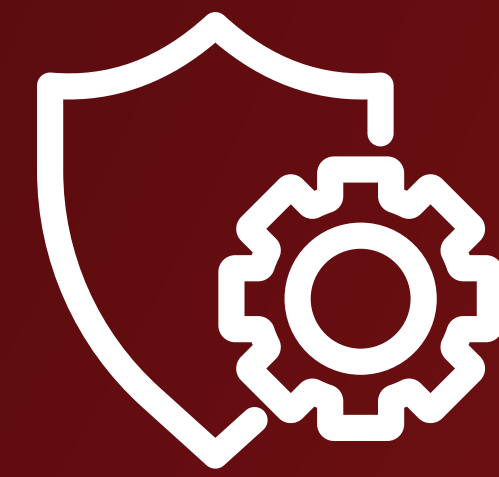
- Employees should be trained to spot behavioural indicators:
- Urgency & pressure: artificial deadlines or threats.
- Requests for risky actions: clicking links, opening attachments, providing credentials.
- Unverifiable context: references to meetings/events that cannot be independently confirmed.
- Message: Behavioural awareness is more reliable than linguistic.



HARVEST NOW, DECRYPT LATER (HNDL)

- Adversaries intercept encrypted data today, planning to decrypt later with quantum computing.
- Risk depends on data sensitivity horizon:
- Short-lived (shift rosters) = Low risk.
- Long-lived (medical records, AI model weights, government docs) = High/Very High risk.
- Action: Begin migration to Post-Quantum Cryptography (PQC) now.
- ASD guidance: all organisations should have a PQC transition plan by end of 2





THE MALWARE ARSENAL

Malware Arsenal

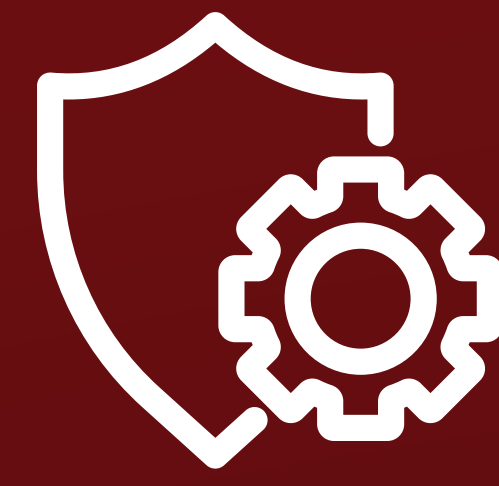
Techniques used by cyber attackers to gain control of business owners.

Ransomware Extortion: The use of modern malware to extract sensitive data and to force secondary targets such as customers to pay.

Information Extraction: The use of malware to extract session tokens, passwords and API keys later exposed on the dark web to facilitate larger enterprise breaches.

Trojan (RATs): The use of Trojan malware to access corporate networks from remote locations by disguising itself as legitimate software.

Spyware: The use of malware to monitor user activity through webcams and capture keystrokes to conduct nation-state espionage.

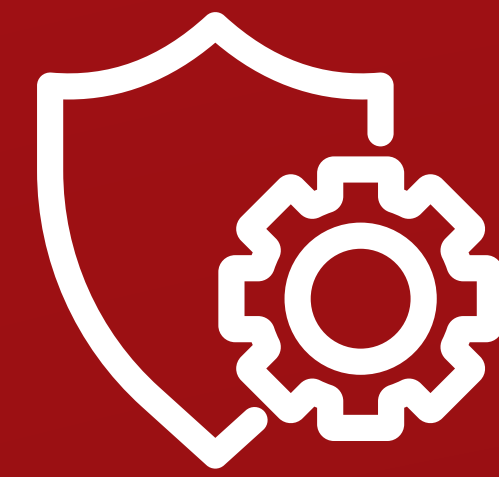


AUTOMATION OF A STAGED ATTACK

MITRE ATT&CK

1. **Initial Access:** Phishing, using stolen session tokens from public applications to gain initial access to the network foothold.
2. **Execution:** Running malicious adversary malware code such as PowerShell scripts on the local or remote host.
3. **Persistence:** Adding accounts and manipulating registries to maintain access to the system despite attempts to clear out malware by restarting the system.
4. **Exfiltration:** Packaging and transferring sensitive enterprise data to external infrastructure controlled by malicious attackers.





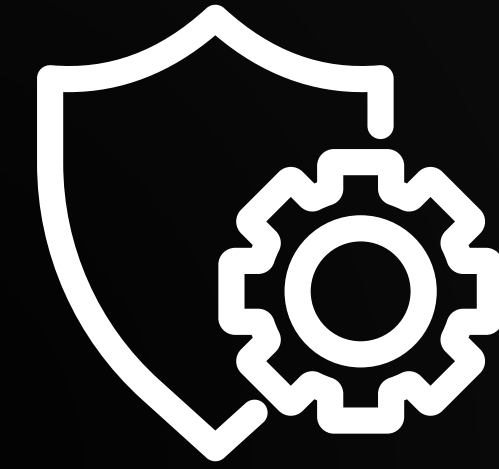
ZERO DAYS

The Window of Exposure

A zero-day is a critical software vulnerability previously unknown to the vendor. Consequently, defenders have "zero days" to fix it before active exploitation begins.

The Lifecycle: Discovery by researchers, immediate weaponisation, active in-the-wild exploitation, vendor discovery, patch development, and finally, enterprise deployment.

The massive reliance on digital supply chains means a single zero-day in a shared component instantly jeopardises millions of interconnected systems globally.



THE PQC IMPARATIVE

The "Harvest Now, Decrypt Later" (HNDL) strategy puts current long-shelf-life sensitive data at immediate risk. Once a Cryptographically Relevant Quantum Computer (CRQC) is built, current public-key encryption (like RSA) will be obsolete. In response, 2026 marked a regulatory turning point with the implementation of NIST's FIPS 203/204/205 standards for Post-Quantum Cryptography (PQC). Organizations must begin transitioning their cryptographic infrastructure to quantum-resistant algorithms immediately to mitigate retroactive exposure.

THREAT INTELLIGENCE

- Sections 2.1-2.3; MITRE ATT&CK framework; Threat actor case studies.

VULNERABILITY RESEARCH

- Section 2.8 (Zero-days); Supply chain attack mapping and examples.

RESEARCH

- Section 2.9 (HNDL/PQC); NIST standards analysis; Risk triage briefing.

INFORMATION SECURITY

- Section 2.7 (Phishing, Vishing, Smishing); AI attack execution types.

Key Takeaways

- Cyber threats are AI-driven, fast, and adaptive.
- MITRE ATT&CK provides a structured lens for analysing multi-stage attacks.
- Supply chain and insider risks remain critical weak points.
- Phishing detection must evolve beyond grammar checks to behavioural cues.
- HNDL requires strategic encryption migration to protect long-lived sensitive data.
- Final message: Cybersecurity demands proactive, AI-enabled, and forward-looking defenses.



THANK YOU!

GENIUS **ARMOURY**

CYBER SECURITY GUARDIANS

Untapped-Talent.com

© UntappedMe. All rights reserved.